ADR-0005 : PowerPoint en téléchargement seul, sans prévisualisation

- **Statut :** Accepté
- **Date :** 2026-07-21
- **Décideurs :** Driss OUAAZIZ — Software Architect

Contexte et problème

FileFlow proposait une prévisualisation riche des présentations PowerPoint (`.pptx`) via la bibliothèque front-end `pptx-preview`, qui restituait les diapositives (formes, texte, tableaux, graphiques).

Un audit des dépendances a révélé que `pptx-preview` :

- tire des dépendances transitives **vulnérables** — `echarts` (faille XSS, gravité modérée) et `uuid` (dépassement de borne mémoire) ;
- écrit en interne du **contenu de diapositive non maîtrisé via `innerHTML`**, un point d'injection DOM neutralisé aujourd'hui uniquement par la politique de sécurité de contenu (CSP) stricte de l'application.

Les CVE d'`echarts` ne sont corrigées que dans une **version majeure** que `pptx-preview` ne prend pas en charge : forcer cette montée risquerait de casser le rendu, sans possibilité de validation navigateur fiable. Le produit conserve par ailleurs une politique explicite de **non-injection de HTML brut**.

Facteurs de décision

- Éliminer les dépendances vulnérables et le point d'injection DOM.
- Ne pas dépendre de la seule CSP comme rempart contre un contenu hostile.
- Préserver un scan de dépendances propre (aucune vulnérabilité résiduelle).
- Conserver un comportement produit cohérent et prévisible.

Options envisagées

1. **Conserver `pptx-preview` en l'état** — Maintient trois avis de sécurité et un sink `innerHTML` alimenté par du contenu non maîtrisé.
2. **Forcer les versions transitives corrigées (overrides)** — Impose `echarts` en version majeure non supportée par `pptx-preview` ; risque élevé de rupture du rendu, non vérifiable de façon fiable.
3. **Remplacer par un rendu maison à partir de l'extracteur existant** — Possible mais représente un développement neuf et une surface à maintenir.
4. **Retirer la prévisualisation PowerPoint** *(retenu)* — PowerPoint devient un type **téléchargement seul**, au même titre que tout format non pris en charge.

Décision

Supprimer la dépendance `pptx-preview` et **retirer toute prévisualisation PowerPoint**. Les fichiers `.pptx` / `.ppt` sont désormais traités comme n'importe quel type non pris en charge : l'ouverture présente le panneau standard « aucune prévisualisation disponible » assorti d'un bouton de **téléchargement**.

Mise en œuvre :

- retrait de `pptx-preview` de `package.json` et des deux lockfiles ;
- exclusion de `pptx` / `pptm` de la liste des extensions prévisualisables (`isPreviewable`), aiguillant ces fichiers vers le repli de téléchargement ;
- suppression du composant de visualisation PowerPoint et du code d'extraction associé désormais inutilisé.

Conséquences

Positives

- Suppression de trois avis de sécurité (`echarts` XSS, `uuid`) et d'un point d'injection `innerHTML` alimenté par du contenu non maîtrisé.
- Audit des dépendances front-end ramené à **zéro vulnérabilité**.
- Réduction du poids du bundle et de la surface de code à maintenir.
- Comportement homogène avec les autres formats non prévisualisés.

Négatives

- **Perte de la prévisualisation en ligne** des présentations : l'utilisateur doit télécharger le fichier pour le consulter.

Risques résiduels

- Si la prévisualisation PowerPoint redevenait une exigence, il faudrait reconstruire un rendu **sans dépendance vulnérable** (par ex. un rendu maison à partir d'une extraction texte/structure), et non réintroduire `pptx-preview` .

Références

- Code : `frontend/src/components/FileViewer.tsx` , `frontend/src/utils.ts` , `frontend/package.json` .
- ADR lié à la posture de sécurité front-end (politique de non-injection HTML, CSP stricte, assainissement DOMPurify des sorties HTML).